- ツール選定と責任や弁明の関係
  - 製品の出荷前チェックのレベルの話と外部からの問い合わせに対応する際の話
    - 「このメジャーなツールで行っているので、十分だと考えます」という承認者への説明
    - ツールに対する承認者が持っている信頼感で、OSSツールより商用ツールが好まれる
      - OSSツールだと決裁もないので、知られていない
    - 承認者が誤解なく理解されるように働きかけることがOSPOの役割になるだろう
    - 説明責任を果たす上で、商用ツールの方が準備されているものがあるので楽。OSSツールでは自分たちで説明を出来ないといけない（自己責任で使っている）
  - 最終的には、問題の発生頻度の見込みとその対策コストのバランスで決めることになるので、各社の業態、規模を勘案して決定することになる
    - ツール選定アルゴリズム、評価式をこのOSPO SubWGで提案できるといいかも
    - どのツールがベストかに、OSS成熟度も関わってくるだろう

- 生成AIとOSPO
  - OSSのカバナンスと生成AI利用のガバナンスが似ている：ベストプラクティスの類似性
  - https://atmarkit.itmedia.co.jp/ait/articles/2601/14/news052.html

 The OpenChain project Japan work group / CC0-1.0

2026/2/27

- SCAツールの選定時のチェックポイント
  - Software Composition Analysis tool
- SCAツールの出力で区別
  - どんなソフトウェアコンポーネントが含まれているかを見つけてリストするタイプ
    - コンポーネントを見つけて、名称、ライセンス、Copyright、、、をリストする
    - コンポーネントを見つける方法にもツールやオプションによって違いがある
  - Scan対象のソフトのライセンス文のパターンや著作権情報、ライセンスに関連する法的なキーワード等を見つけてリストするタイプ（例: FOSSology）
    - どのディレクトリにこのライセンスを示す情報があるかを見つけてリストする
      - ディレクトリ構成・名称が適切だと、コンポーネント名とライセンスのペアが作れる
- スキャン方法の区別
  - OSSのデータベースと対象ソフトを照合する
  - Scan対象のソフトのライセンス文のパターンや著作権情報、ライセンスに関連する法的なキーワード等を見つける
  - AIを利用して、OSSのコードのデータベースと対象ソフトを比較し、AIによるコード解析も利用しながら精度よく解析する（参考　https://semcl.one/）
    - Snippetを見つける精度が高そう
  - バイナリスキャン
    - シンボルテーブルのシンボル名とデータベースにあるシンボルとの一致性を見て判定
    - バイナリのコードパターン（フィンガープリント）の類似性を見る
- チェックポイントの候補
  - リポジトリのツリー構成が適切であれば、キーワード検索タイプでも有用
    - OSS利用する開発のお行儀・教育が行き届いているならこのタイプでも事足りる
  - Snippetの発見を重視するなら、それに適したコンポーネント検出アルゴリズムのツールを選ぶ
  - それぞれの会社の最終的な利用目的、作業手順、プロセスのどこで利用するかによって個別のチェックポイントがあるだろう

The OpenChain project Japan work group / CC0-1.0

- 精度面
  - ソースは行儀よく管理されていると精度が高くなる
  - バイナリスキャンが必要な状況
    - バイナリリリースを受けた場合
    - リリース先からどのように見えるかを知りたい
    - 意図しないソースコードがコンパイルされていないか
    - 意図しない外部ライブラリが結合されていないか
  - SCAツールで100%正確なスキャン結果は無理
    - SCAツールだけでなく、作成時の作法やコード整形ツールなどいろいろな手段を組み合わせて精度を上げることを考える方が良い
- バイナリスキャンの手法
  - シンボル名などの特徴、傾向を見て、見つけ出す

The OpenChain project Japan work group / CC0-1.0

- 外部からの違反指摘を受けた時に何をすることになるか
  - 想定する指摘：
    - 「XXXというGPLソフトを使っているのではないですか。ソースコードを提供してください。」
    - 誰が受けるか
      - ①OSPO的なところ、②会社の問い合わせ窓口、③その製品のサポート窓口、④公開リポジトリ経由、⑤外部のSNSで情報が流れた、⑥従業員が個人的に外部から相談された
  - アクション：
    - 問い合わせ・情報を得た人が速やかに社内の適切な部門（OSPO）に連絡するように周知が必要
    - 本当にXXXを使っているかどうかを調査する
      - 該当の製品を開発した（取り扱った）プロジェクトの人を見つけて確認する
      - 製品情報としての記録（保管してあるソースリポジトリ）を調査
      - 外部調達ソフトが組み合わされている場合は、その調達元に問い合わせ
    - 製品上のバイナリをスキャンして確認
    - XXXが含まれていないと判断した場合：
    - XXXが含まれていると確認できた場合：
      - まずは、ソースコードを提供できるかどうか検討
      - ソースコードの提供が出来ないとなった場合
        - 技術サイドの対応
          - 製品販売を停止
          - XXXを使わない製品に修正して、販売再開
        - ビジネスサイドの対応
          - 違反を認め、対応について権利者と協議
  - そもそも、このようなことが起こらないように開発初期から気を付けることが大事
    - 外部調達も含めてサプライチェーン全体で気を付ける
    - ここもOSPOの役割として大切

The OpenChain project Japan work group / CC0-1.0

もしOSPOがなければどうなるか

The OpenChain project Japan work group / CC0-1.0